

Mémoire SCR DORA : le modèle en clair

Cascades entre piliers et contagion, sans le formalisme

Kélian Kaddouri

ENSAE / Nexialog Consulting

20 juillet 2026

Pourquoi cet échange

- Le mémoire relie trois choses : le risque **cyber**, la conformité **DORA** et le **capital de solvabilité** (SCR).
- Point de départ : la Formule Standard sous-estime le cyber, parce qu'elle ne voit pas la **contagion** entre les fonctions d'une entité.
- Je te présente le modèle en clair, sans les équations.

Ce que j'attends de toi : ton regard opérationnel, et surtout un point de blocage sur les **données** pour calibrer la contagion.

L'idée centrale, en une phrase

On ne note pas un **ensemble** de piliers DORA touchés, mais une **chaîne ordonnée** d'effondrement.

- Une cascade qui suit une direction causale plausible (la gouvernance qui lâche, puis les conséquences) est un vrai emballement : plus **probable** et plus **grave**.
- Le même ensemble de piliers pris **à l'envers** est rare et peu grave.

C'est l'ordre qui pilote le verdict, pas seulement la liste des piliers touchés.

Les cinq piliers de DORA

- **P1** : gouvernance et gestion du risque TIC (la fondation).
- **P2** : gestion des incidents.
- **P3** : tests de résilience (TLPT).
- **P4** : gestion du risque lié aux tiers (cloud, prestataires critiques).
- **P5** : partage d'informations (volontaire).

Intuition de terrain : **P1 et P4** sont plutôt des déclencheurs en amont, **P5** est plutôt en bout de chaîne.

Trois jugements d'expert, rien d'autre

Tout le modèle qualitatif tient sur trois barèmes, ordonnés à dire d'expert :

- **Qui amorce** : quel pilier a le plus de chances de démarrer une cascade.
- **Qui entraîne qui** : la force du lien « tel pilier en entraîne tel autre », et surtout elle est **asymétrique** (P1 entraîne beaucoup, l'inverse très peu).
- **La gravité propre** de chaque pilier s'il tombe seul.

Tu reconnaîtras l'esprit du **RPN de l'AMDEC** et des matrices de criticité des **dashboards ORSA**. La seule nouveauté : ici, la **direction** (qui entraîne qui) change la note.

La criticité : proba croisée avec gravité

Comme une matrice de risque : criticité = probabilité **croisée avec** gravité, lue en catégories (de Faible à Extrême). Même paire de piliers, deux sens :

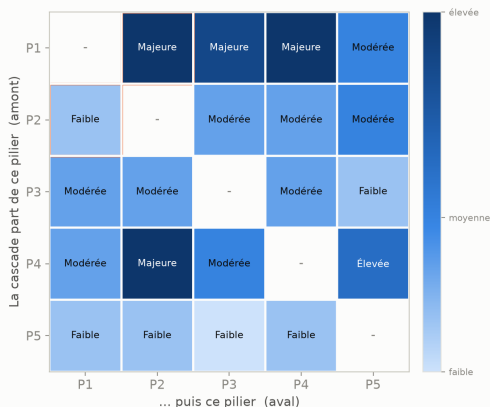
	1 vers 2 <i>gouvernance puis incident</i>	2 vers 1 <i>incident puis gouvernance</i>
Probabilité	Probable	Très rare
Gravité	Critique	Modérée
Criticité	Majeure	Faible

Mêmes deux piliers, **verdict opposé** : tout l'écart vient de la cohérence causale de l'ordre.

L'ordre renverse le verdict

L'ordre renverse le verdict

Criticité d'une cascade à 2 piliers selon le SENS. Cadres orange : 1→2 « Majeure » vs 2→1 « Faible » : mêmes piliers.

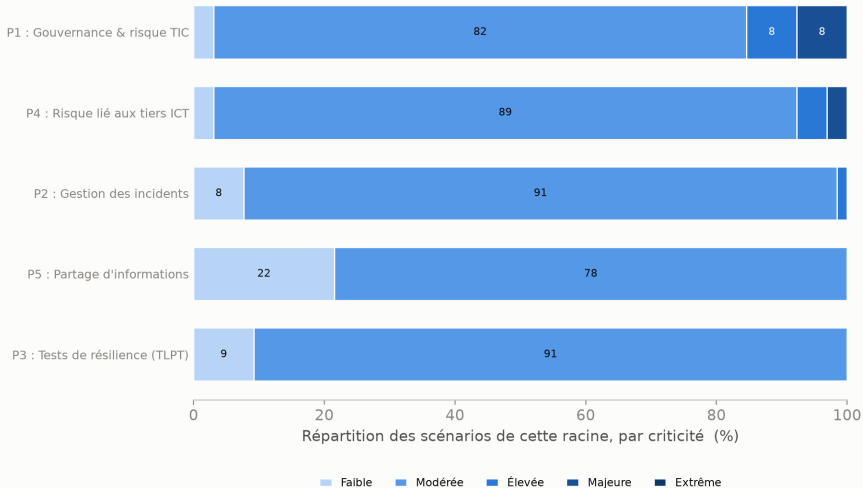


Mêmes piliers, sens opposés : 1 vers 2 ressort **Majeure**, 2 vers 1 ressort **Faible**. Une simple corrélation serait symétrique et raterait cela.

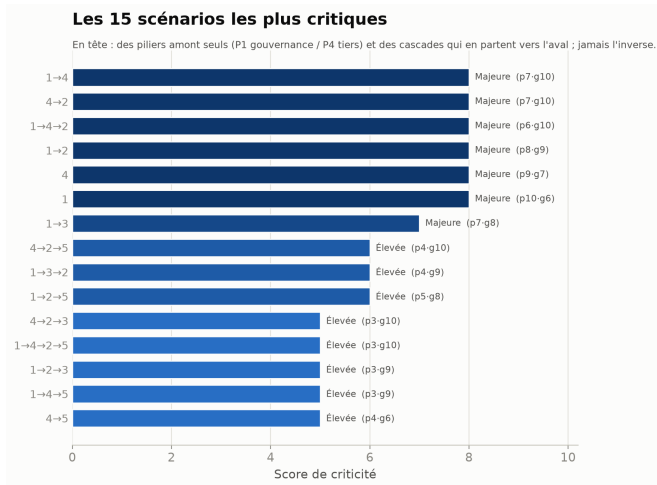
Le pilier qui amorce fait le verdict

Là où la cascade démarre décide de tout

Criticité selon le pilier qui AMORCE la chaîne. P1/P4 en tête → verdicts lourds ; P5 → quasi jamais.



Les scénarios les plus critiques



En tête : des cascades qui partent de l'amont (gouvernance, tiers) vers l'aval, jamais l'inverse. Les scores ne servent qu'à trier ; on lit des catégories.

Du classement au capital : la contagion

Jusqu'ici c'est **qualitatif**. Pour le capital, on injecte la même information d'expert (le « qui entraîne qui ») dans le modèle quantitatif.

- Un pilier sous stress **contamine** les autres piliers de la même entité : une **boucle de contagion**, pas une corrélation posée après coup.
- On **borne** cette boucle pour qu'elle reste stable (sinon la perte part à l'infini).

Honnêteté sur le statut

C'est une adaptation d'un modèle de risque de crédit (Vasicek) : on gagne la contagion dirigée, au prix de certaines propriétés théoriques. On l'assume et on le dit.

Une cascade doit pouvoir s'éteindre

- Sans garde-fou, la chaîne ne s'arrête jamais et la sévérité explose.
- On donne à chaque pilier une **probabilité de tout arrêter**.
- **P5** (partage d'informations) éteint souvent la cascade ; **P1** presque jamais.
- Règle : un pilier ne défaille qu'une fois (cascade « auto-évitante »).

Résultat : une perte finie, et des piliers naturellement en bout de chaîne (comme P5).

Là où j'ai besoin de ton avis

- ❶ **Calibrer la contagion** (le « qui entraîne qui ») : aujourd'hui c'est du jugement d'expert. Les bases de pertes ne codent pas les piliers **co-touchés**, les bases de brèches n'ont pas l'**horodatage** fin.
 - Existe-t-il, chez tes clients ou en interne, un **registre d'incidents horodaté** (proche du format de reporting DORA) exploitable ? Sur quel périmètre ?
- ❷ **La sévérité** : aujourd'hui la gravité d'un pilier est un **score ordinal**, pas un montant. Comment passer proprement à des **euros par pilier** ?
- ❸ **Le réalisme de terrain** : l'ordre P1/P4 en amont, P5 en aval, ça colle à ce que tu vois en mission ?

Ce que je retiens de cet échange

- Ta lecture opérationnelle de l'ordre des piliers (amont vers aval).
- Une piste de **donnée** : incidents codés par pilier et/ou horodatés.
- Une **maille de coût** par pilier crédible côté métier.

Merci. Je te laisse les slides et les PDF détaillés pour ton retour.